

# Capstone Task 3: Utilizzo di NMap su CyberOPS WorkStation

Data: 21/02/2026

Analista: Daniele di Martino - Bkm4ge

## Introduzione

Per la task odierna viene richiesto di utilizzare la VM CyberOPS Workstation e l'utilizzo di NMap sulla macchina.

Si riconosce che la scansione delle porte fa solitamente parte di un attacco di ricognizione. Esistono diversi metodi di scansione delle porte utilizzabili. In questa task verrà illustrato come usare l'utility Nmap. Nmap è una potente utility di rete usata per la scoperta della rete e l'audit di sicurezza.

---

## Step 1: Esplorazione di NMap

Aprendo il terminale e digitando il comando `man nmap` verrà mostrato il manuale con la descrizione del tool, tutti i possibili impieghi e le features che ospita.

## NAME

nmap - Network exploration tool and security / port scanner

## SYNOPSIS

**nmap** [Scan Type...] [Options] {target specification}

## DESCRIPTION

Nmap ("Network Mapper") is an open source tool for network exploration and security auditing. It was designed to rapidly scan large networks, although it works fine against single hosts. Nmap uses raw IP packets in novel ways to determine what hosts are available on the network, what services (application name and version) those hosts are offering, what operating systems (and OS versions) they are running, what type of packet filters/firewalls are in use, and dozens of other characteristics. While Nmap is commonly used for security audits, many systems and network administrators find it useful for routine tasks such as network inventory, managing service upgrade schedules, and monitoring host or service uptime.

The output from Nmap is a list of scanned targets, with supplemental information on each depending on the options used. Key among that information is the "interesting ports table". That table lists the port number and protocol, service name, and state. The state is either open, filtered, closed, or unfiltered. Open means that an application on the target machine is listening for connections/packets on that port. Filtered means that a firewall, filter, or other network obstacle is blocking the port so that Nmap cannot tell whether it is open or closed. Closed ports have no application listening on them, though they could open up at any time. Ports are classified as unfiltered when they are responsive to Nmap's probes, but Nmap cannot determine whether they are open or closed. Nmap reports the state combinations open|filtered and closed|filtered when it cannot determine which of the two states describe a port. The port table may also include software version details when version detection has been requested. When an IP protocol

Quindi viene fornita la sinossi del comando (importante per non incappare in errori di sintassi), e la sua descrizione:

Nmap in breve, è un tool open source pensato per l'**esplorazione delle reti** e il **security auditing**, utilizza pacchetti raw a basso livello (socket raw) ed è scritto in C/ C++.

La caratteristica di NMap permette di forgiare autonomamente gli header, manipolando bit e flag specifici per osservare le reazioni del target.

## Tipo di Output

Scorrendo nella pagina del manuale, nmap mostra un determinato tipo di output a seconda delle caratteristiche di scansione scelte, ad esempio:

```
# nmap -A -T4 scanme.nmap.org

Nmap scan report for scanme.nmap.org (74.207.244.221)
Host is up (0.029s latency).
rDNS record for 74.207.244.221: li86-221.members.linode.com
Not shown: 995 closed ports
PORT      STATE      SERVICE      VERSION
22/tcp    open      ssh          OpenSSH 5.3p1 Debian 3ubuntu7 (protocol 2.0)
|_ ssh-hostkey: 1024 8d:60:f1:7c:ca:b7:3d:0a:d6:67:54:9d:69:d9:b9:dd (DSA)
|_ 2048 79:f8:09:ac:d4:e2:32:42:10:49:d3:bd:20:82:85:ec (RSA)
80/tcp    open      http         Apache httpd 2.2.14 ((Ubuntu))
|_ http-title: Go ahead and ScanMe!
646/tcp   filtered  ldp
1720/tcp  filtered  H.323/Q.931
9929/tcp  open      nping-echo   Nping echo
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6.39
OS details: Linux 2.6.39
Network Distance: 11 hops
Service Info: OS: Linux; CPE: cpe:/o:linux:kernel

TRACEROUTE (using port 53/tcp)
HOP RTT      ADDRESS
[Cut first 10 hops for brevity]
11  17.65 ms li86-221.members.linode.com (74.207.244.221)

Nmap done: 1 IP address (1 host up) scanned in 14.40 seconds
```

con il comando “**nmap -A -T4**” si otterrà una scansione rapida (T-4 = aggressive, richieste molto rapide ad alta rilevazione da parte di sistemi di sicurezza come gli IDS) e aggressiva (-A) che mostra ogni singolo dettaglio della macchina target.

In una logica di attacco, un firewall stateful avrebbe bloccato la richiesta, comandi di questo genere vengono lanciati da amministratori di sistema per valutare le performance dei sistemi di reti in manutenzione.

## Movimenti all’interno del manuale

Per cercare ciò che serve, ci si sposta nel manuale con i seguenti comandi:

- freccia su e freccia giù: permette di scorrere nelle righe del manuale
- barra spaziatrice: pagina successiva
- /: ad esempio /example, cercherà avanti nel documento il termine example
- ?: ? example, cercherà all'indietro nel documento

## Step 2: scansione target

Per muovere i primi passi, si procede a configurare la stessa scansione di rete come nell'esempio sopracitato, ma con il localhost:

`nmap -A -T5 localhost`

```
[analyst@secOps ~]$ nmap -A -T5 localhost
Starting Nmap 7.97 ( https://nmap.org ) at 2026-02-21 05:22 -0500
Nmap scan report for localhost (127.0.0.1)
Host is up (0.000035s latency).
Other addresses for localhost (not scanned): ::1
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.0.8 or later
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_-rw-r--r--    1 0          0          0 Mar 26  2018 ftp_test
| ftp-syst:
|   STAT:
| FTP server status:
|   Connected to 127.0.0.1
|   Logged in as ftp
|   TYPE: ASCII
|   No session bandwidth limit
|   Session timeout in seconds is 300
|   Control connection is plain text
|   Data connections will be plain text
|   At session startup, client count was 3
|   vsFTPD 3.0.5 - secure, fast, stable
|_End of status
22/tcp    open  ssh      OpenSSH 10.0 (protocol 2.0)
Service Info: Host: Welcome
```

Viene così mostrato:

- il livello di privilegi: attualmente analyst non è root, quindi viene chiusa quasi istantaneamente la connessione
- le porte aperte: 21 e 22
- versioni dei servizi sulle porte attive: vsftpd 2.0.8 su 21 e OpenSSH 10.0 su 22

- la possibilità di loggarsi come anonymous e senza password e la possibilità di leggere in root il file ftp\_test

---

## Step 3: identificazione degli IP

Con il comando “ip address” vengono identificate comunemente le interfacce di rete

```
[analyst@secOps ~]$ ip address
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: enp0s3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:2f:87:a7 brd ff:ff:ff:ff:ff:ff
    altname enx0800272f87a7
    inet 10.0.2.15/24 metric 1024 brd 10.0.2.255 scope global dynamic enp0s3
        valid_lft 81959sec preferred_lft 81959sec
    inet6 fd17:625c:f037:2:a00:27ff:fe2f:87a7/64 scope global dynamic mngtmpaddr noprefixroute
        valid_lft 86215sec preferred_lft 14215sec
    inet6 fe80::a00:27ff:fe2f:87a7/64 scope link proto kernel_ll
        valid_lft forever preferred_lft forever
```

Identificazione localhost: 127.0.0.1 /8

IP macchina: 10.0.2.15/24

## Localizzazione di host secondari all'interno della rete

Con il comando nmap -A -T5 192.168.1.0/24 sarà possibile scansionare tutti i dispositivi all'interno della rete poiché il target ora è il gateway.

```

Nmap scan report for 192.168.1.2
Host is up (0.023s latency).
Not shown: 999 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
80/tcp    open  http      TP-LINK router http config
|_http-title: Opening...

Nmap scan report for 192.168.1.43
Host is up (0.000057s latency).
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp       vsftpd 2.0.8 or later
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_-rw-r--r--  1 0      0          0 Mar 26  2018 ftp_test
| ftp-syst:
|   STAT:
| FTP server status:
|   Connected to 192.168.1.43
|   Logged in as ftp
|   TYPE: ASCII
|   No session bandwidth limit
|   Session timeout in seconds is 300
|   Control connection is plain text
|   Data connections will be plain text
|   At session startup, client count was 2
|   vsFTPD 3.0.5 - secure, fast, stable
|_End of status
22/tcp    open  ssh       OpenSSH 10.0 (protocol 2.0)
Service Info: Host: Welcome

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 256 IP addresses (3 hosts up) scanned in 104.45 seconds

```

Vengono rilevati il PC host e il wifi extender; mancano all'appello il dispositivo mobile; Questo deriva dall'architettura dei dispositivi Android, pensati per risparmiare energia e non rispondere sempre alle richieste ARP che vengono indirizzate.

Altro tratto interessante è la scoperta di anomalie di sicurezza relative a 192.168.1.43:

```

FTP server status:
  Connected to 192.168.1.43
  Logged in as anonymous
  TYPE: ASCII
  Session bandwidth limit in byte/s is 10485760
  Session timeout in seconds is 600
  Control connection is plain text
  Data connections will be plain text
  At session startup, client count was 1
  vsFTPD 2.0.3 - secure, fast, stable
_End of status
_ftp-anon: Anonymous FTP login allowed (FTP code 230)
2/tcp open  ssh          (protocol 2.0)
  fingerprint-strings:
    NULL:
    _SSH-2.0-dropbear_
3/tcp open  telnet      BusyBox telnetd 1.00-pre7 - 1.14.0
  fingerprint-strings:
    GenericLines:
    F6746G
    Login:

```

Presenta una **superficie di esposizione critica** e configurazioni legacy.

- **Protocolli in Chiaro (Livello di Rischio: Elevato):** Il dispositivo espone servizi di amministrazione e trasferimento dati privi di crittografia, nello specifico Telnet (porta 23, gestito da BusyBox) e FTP (porta 21). L'FTP, inoltre, ammette connessioni anonime.
- **Vulnerabilità Architetturel SMB:** Le porte 139 e 445 rivelano un demone Samba configurato in modo estremamente permissivo.

L'Nmap Scripting Engine ha rilevato l'**authentication\_level: share** (una modalità obsoleta e intrinsecamente insicura) e la disabilitazione della firma dei pacchetti (message signing disabled). Questo rende teoricamente l'host suscettibile ad attacchi di tipo Man-in-the-Middle (MitM) o relay sul protocollo SMB.

Nota di merito va invece a 192.168.1.2: access point

Questo dispositivo mostra un comportamento difensivo rigoroso.

- **Filtraggio Stateful:** A differenza del gateway ZTE, questo host ha scartato silenziosamente le sonde dirette a 999 porte (classificate come **filtered / no-response**). Ciò denota la presenza di regole di firewalling (ACL) ben implementate

che bloccano il traffico in ingresso, lasciando aperta la sola porta 80 per l'interfaccia di amministrazione web.

---

## Step 4: Localizzazione di host in rete

Per l'ultima task viene chiesto di aprire un browser web alla pagina [scanme.nmap.org](https://scanme.nmap.org) per ufficializzare la connessione.

Successivamente viene lanciato il comando di nmap verso l'indirizzo DNS sopra menzionato, il risultato è il seguente:

```
[analyst@secOps ~]$ nmap -A -T5 scanme.nmap.org
Starting Nmap 7.97 ( https://nmap.org ) at 2026-02-21 06:46 -0500
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.19s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f
Not shown: 992 closed tcp ports (conn-refused)
PORT      STATE      SERVICE      VERSION
22/tcp    open      ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   1024 ac:00:a0:1a:82:ff:cc:55:99:dc:67:2b:34:97:6b:75 (DSA)
|   2048 20:3d:2d:44:62:2a:b0:5a:9d:b5:b3:05:14:c2:a6:b2 (RSA)
|   256 96:02:bb:5e:57:54:1c:4e:45:2f:56:4c:4a:24:b2:57 (ECDSA)
|_  256 33:fa:91:0f:e0:e1:7b:1f:6d:05:a2:b0:f1:54:41:56 (ED25519)
80/tcp    open      http         Apache httpd 2.4.7 ((Ubuntu))
|_ _http-title: Go ahead and ScanMe!
|_ _http-favicon: Nmap Project
|_ _http-server-header: Apache/2.4.7 (Ubuntu)
135/tcp    filtered  msrpc
139/tcp    filtered  netbios-ssn
445/tcp    filtered  microsoft-ds
593/tcp    filtered  http-rpc-epmap
9929/tcp   open      nping-echo   Nping echo
31337/tcp  open      tcpwrapped
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 25.98 seconds
```

- porte aperte e servizi esposti e versioni:
  - 22 ssh OpenSSH 6.6.1p1
  - 80 http Apache httpd 2.4.7
  - 9929 nping-echo Nping echo
  - 31337 tcpwrapped
- porte filtrate e servizi:
  - 135 msrpc

- 139 netbios-ssn
  - 445 microsoft-ds
  - 593 http-rpc-epmap
  - OS: Linux
- 

## Conclusioni

Come può Nmap aiutare con la sicurezza della rete?

Come può Nmap essere usato da un attore malevolo come strumento nefasto?

Analizziamone i punti:

### Validazione Difensiva e Hardening (Postura di Sicurezza)

Nell'ambito della gestione sistemica e della difesa perimetrale, Nmap funge da strumento di audit empirico e inconfutabile per misurare la discrepanza tra la configurazione teorica della rete e il suo stato reale operativo.

- **Mappatura della Superficie di Esposizione:** Permette agli amministratori di identificare asset non documentati (dispositivi *Shadow IT*) o servizi legacy dimenticati (come il demone `vsftpd` con accesso anonimo rilevato nella tua topologia di test).
  - **Verifica delle Policy di Segmentazione:** Nmap testa fattualmente l'efficacia delle Access Control List (ACL) e dei firewall. Analizzando le metriche di risposta (porte classificate come `filtered` o `closed`), convalida che i perimetri logici e le VLAN siano effettivamente isolati.
  - **Vulnerability Assessment Proattivo:** Attraverso il Nmap Scripting Engine (NSE), il sistema può interrogare i demoni in modo automatizzato per verificare l'applicazione di patch critiche, la validità dei certificati SSL o la presenza di *cipher suite* crittografiche obsolete.
  - **Risposta agli Incidenti (Incident Response):** Durante la gestione di un'anomalia, una scansione differenziale rapida può isolare istantaneamente nodi compromessi che hanno inaspettatamente aperto nuove porte per comunicazioni di *Command and Control* (C2) o reverse shell.
- 

### Applicazione Teorica nella Cyber Kill Chain (Attori Malevoli)

In un'ottica offensiva e di *Red Teaming*, Nmap viene impiegato operativamente nella prima fase della *Cyber Kill Chain*: la ricognizione attiva. L'obiettivo sistemico dell'attaccante è mappare l'infrastruttura per minimizzare l'entropia dell'attacco e massimizzare la percentuale di penetrazione silente.

- **Identificazione del Vettore Primario (Initial Access):** Un attore malevolo analizza i banner applicativi (es. identificando esattamente **OpenSSH 5.3p1**) per correlare la topologia con i database delle vulnerabilità pubbliche (CVE), pianificando lo sviluppo o l'adattamento di exploit specifici per la singola versione del demone.
- **Elusione dei Sensori (Evasion):** Sfruttando la manipolazione avanzata degli header RAW, l'attaccante può frammentare i pacchetti IP, generare traffico sorgente fittizio (Decoys) o alterare i valori di *Maximum Transmission Unit* (MTU) per camuffare le sonde, sfalsare le firme di rilevamento e bypassare le logiche degli Intrusion Detection Systems (IDS).
- **Pianificazione del Movimento Laterale:** Una volta compromesso un host periferico debole, l'attore malevolo proietta Nmap all'interno della rete (spesso tramite proxy o tunnel SOCKS) per eseguire uno *stealth sweep*, identificare i domain controller o i server database e tracciare le rotte ottimali per l'esfiltrazione dei dati o l'escalation dei privilegi.
- **Enumerazione per Social Engineering:** Identificando tipologie di stampanti multifunzione, server VoIP o specifici sistemi operativi client, l'attaccante acquisisce dati contestuali essenziali per forgiare campagne di *spear-phishing* o ingegneria sociale tecnicamente credibili.